



SECURITY AUDIT REPORT

Contents

Introduction	2
Executive Summary.....	2
Brief overview of the company:.....	2
Scope of the assessment:.....	2
Organisational structure:	3
Risk Assessment and analysis	4
Risk assessment team	4
Asset Identification and classification.....	4
Vulnerabilities & Threats	6
Overall risk calculation by Using Factor Analysis of Information Risk (FAIR).....	8
Why we chose FAIR?	8
Risk Mitigation – ISO 27001	11
Proposed mitigating controls (based on ISO 27001 controls)	11
Statement of Applicability (SOA)	14
Risk Reduction (SOA).....	15
Risk treatment plans – Risk acceptance, risk treatment, risk transfer and risk avoidance	17
Risk Communication Plan	20
Business Continuity Plan	21
Business Impact Analysis	21
Recovery Time Objectives (RTO).....	21
Recovery Point Objectives (RPO)	22
Disaster Recovery Plan.....	22
Conclusion:.....	24
References	24

Introduction

Executive Summary

The focus of this research is to provide a thorough security audit with important findings for Megahotel, one of the top hotel chains in the UK. They are well-known for providing exceptional guest services and are committed to upholding the reputation of their brand. To grow its business, Megahotel plans to expand through the acquisition of a smaller chain known as Value Chain. This has raised concerns about potential security threats, highlighting the need for a comprehensive review of existing information security arrangements and management structures.

The Chief Information Security Officer (CISO) is concerned about potential threats, so he hired our group, Eisha Aiman Chaudary, and Hafiz Hassan Ahmed, to audit the company's current assets, assess potential threats that the merger could introduce, and provide a business continuity and treatment plan.

To identify the assets at risk and draw attention to their vulnerabilities and potential risks, we initially reviewed the process in this audit. Going forward, we implemented risk reduction in compliance with ISO 27001 standards, suggesting the strategy for risk reduction and the controls required to calculate the risk.

In addition, we described the risk communication plan for informing stakeholders about the risk. The suggested report also includes a disaster recovery plan for each asset's backup plan in the event of a cyberattack, as well as a business continuity strategy to help keep the workflow running in the event of a threat. The focus of this report is to assess the security audit of Megahotel along with the organization's compliance posture with regulations such as

- UK Data Protection Act 2018
- GDPR
- PCI DSS
- ISO 27001
- FAIR

The audit's conclusion also highlights the system's possible vulnerabilities, risk level, frequency of losses, and business continuity plan and offers suggestions for mitigating them.

Brief overview of the company

Megahotel has a global reputation for offering top-notch services to its patrons. It works in an extremely delicate and regulated industry, handling sensitive and private customer data while maintaining data security and protecting client privacy. Megahotel hopes to combine with Valuechain, a smaller chain, because of its expanding business. Data availability to new chains is expected to increase data loss due to various cyberattack types. The organization's IT infrastructure, which consists of servers, client devices, network devices, and cloud-based technologies spread across multiple regions, including Europe, as well as the involvement of remote staff from various countries with varying rules and regulations as well Megahotel holds a highly sophisticated IT infrastructure updated recently. With the advancement in technology, the Megahotel invested for the latest modern network technology used in the world. Even With the current advanced IT infrastructure there could be some possible network safety threats from this merger, which we will assess during this security audit.

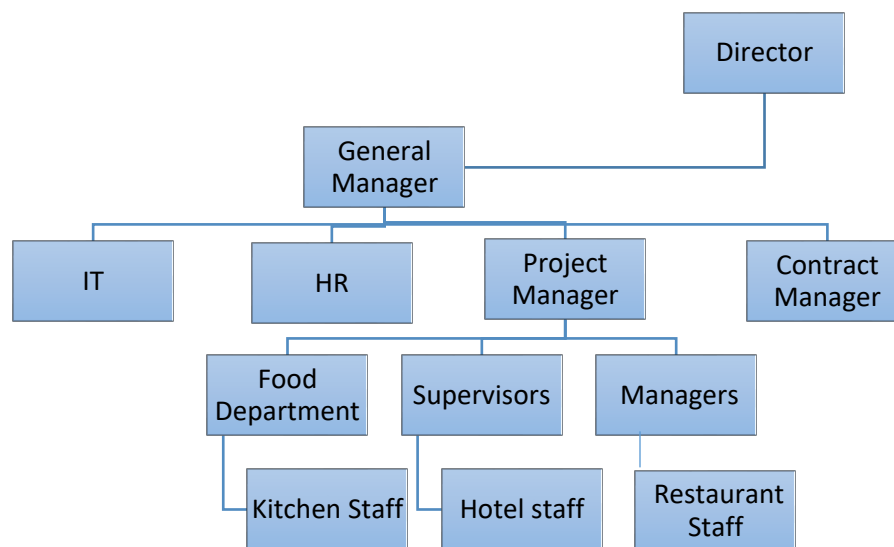
Scope of the assessment

Due to the sophisticated IT architecture of Megahotel, assessment must be done with precision and thoroughness to prevent misunderstandings and mistakes. The organization's IT systems were thoroughly examined, and the security framework running the key departments were evaluated. Data regulations compliance, challenges, and the logical and physical components of the systems were all included in the security audit report. The security audit report provided covers not only a comprehensive evaluation of Megahotel IT infrastructure, but also the compliance of information security practices with current data regulations.

Some of the major areas of concern for this assessment include Recording and examining all IT resources, such as devices, software, and hardware, servers, networks. Making sure that private information is shared, accessed, and stored in a secure way in compliance with laws like the UK Data Protection Act of 2018, PCI DSS, and GDPR.

After identifying all the main assets, their threats, vulnerabilities, and existing controls, we performed Factor Analysis Information Risk (FAIR) method for risk assessment, and we used ISO 27001 guidelines to mitigate the existing risks and created a business continuity plan. Additionally, new controls were implemented according to the ISO 27001 document.

Organisational structure



Risk Assessment and Analysis

Risk assessment Team

The risk assessment team consists of 2 persons, who are both information security audit experts. The responsibilities and tasks are equally divided between these two members, reporting to the Chief Information Security Officer (CISO) for audit and assessment results.

The risk assessment team (RAT) ensures the creation, evaluation, assessment, and mitigation of the whole risk assessment document. The following table shows a clear picture of the RAT.

<u>Person 1</u>	<u>Person 2</u>
Asset Identification and Classification	Vulnerabilities
Severities and Threats	Existing Controls
FAIR	FAIR
Statement of applicability	Mitigation Controls
Risk reduction	Risk treatment plan
Risk Communication Plan	Business Continuity Plan
Recovery time objectives	Recovery point objectives

Asset Identification and classification

Any significant data, apparatus, or other system component of an organization is considered an asset, frequently because it houses or allows access to sensitive data. An employee's corporate phone, laptop, or desktop computer, along with the apps on them, would be considered an asset. In a similar vein, assets include essential infrastructure such as servers and support systems. Information assets are an organization's most common assets. These consist of physical files and databases, or the private data maintained. Below is a detailed list of Megahotel assets.

Name of the Asset	Description	Classification	Asset Owner
Computers	support a range of tasks related to administration and operations	Hardware	IT Departement
Hard Drives	store and manage massive amounts of data vital for a variety of operational and administrative functions	Hardware	IT Departement
Routers	enable the deployment of device communication and internet connectivity	Hardware	Network Administrator
Switches	enable the managment and distribution of data flow with in the LAN	Hardware	Network Administrator
Firewalls	protect the IT system against malicious conduct, cyberattacks, and illegal access.	Hardware	Network Administrator
Door Access Systems	control access to different areas of the property to ensure security, and efficiency in operation	Hardware	Security Departement
CCTV cameras	enhance safety, security, and operational effectiveness by offering ongoing monitoring, activity discouragement, and documentation	Hardware	Security Departement
Smart Devices	customer and internal devices connected to local network	Hardware	IT Departement
Card Machines	allow electronic payments for goods and services between visitors and the hotel	Hardware	Accounting Departement
Wifi Extenders	expand the reach of wireless networks and enhance connection in places where WiFi signals are spotty or nonexistent	Hardware	Network Management Departement
Power Sources	provide continuous electrical power in the event of a mains interruption or breakdown	Hardware	Engineering Departement
Data center	store, process and manage digital data and information technology infrastructure	Hardware	IT Departement
Employee Service Centers	centralized spots within the hotel where staff members cangain access to different HR services	Software	HR Departement
Social media accounts	helps in Brand awareness, Promotion, Engaging Customers, and Developing Relationships	Software	Marketing Departement
Payroll systems	effective administration of associated financial procedures and staff compensation	Software	Finance Departement
Website and booking apps	play a critical role in attracting visitors, making reservations, and improving the experience for visitors	Software	Marketing and IT Departement
Customer service management software	Facilitates the effective management of visitor interactions, inquiries, demands, and comments.	Software	Administration
Inventory software	tasks, such as placing orders, keeping track of inventories, organising menus, and serving guests	Software	Supply Chain Department
Cloud Database	store, organize and access large amounts of data related to hotel operations, visitors information, transactions and reservations	Software	IT Departement
Supply Management systems	enable effective stock, supply, and products management for a variety of hotel operations	Software	Procurement Department

Vulnerabilities & Threats

A vulnerability in an IT system is a weakness that an attacker could exploit to carry out a successful attack. They could be the result of human error, features, or faults, and attackers will try to take advantage of any of them, frequently by combining several. (Ncsc.gov.uk, 2022)

Any occurrence that has the potential to harm a system that is made feasible by a system vulnerability is considered a threat. It could appear as a software attack, denial-of-service attack, physical attack that substantially damages the asset or disrupts operations, or data breach.

Severity on the risk matrix indicates how serious the most likely outcome of a certain hazard event is. In other words, what is the likely severity of the problem if a hazard emerges and is not reduced? As ICAO says of severity, “the severity... of a hazard’s projected consequence.” (Britton, 2019)

All the assets listed above are vulnerable, weak, and exploitable by attackers or hackers due to threats.

Existing controls

Existing controls of the assets in defence against threats are those controls that are currently being implemented by the organization. It will help to work against any potential threats to the hotel, and after detailed analysis, we considered that the current controls are insufficient to prevent the indicated threats. Some important existing controls are:

1. Data backups
All related data have proper backups and on cloud storage
2. Data Encryption
Sensitive data must be encrypted, and it must cover both rest and transit states
3. Secure communication channels
All communication channels emails, phones, radio channels must be secured
4. Network security
VPNs implementation and WI-FI networks with stronger passwords for safe browsing
5. Physical Security:
Security guards, CCTVs, and access control systems at control points
6. Multi factor authentication

Below is a detailed list of all assets with their threats and vulnerabilities. It also contains existing controls that are currently being implemented by Megahotel.

Name of Asset	Threat	Vulnerabilities	Existing Controls
Payroll systems	unauthorized access Fraudulent Conduct	Insufficient Encryption Outdated Software and Patch Management	Data Backups Audit Trails Approval Processes
Hard Drives	physical damage malware infections Data Corruption	Data Remanence, Improper Disposal Lack of data security	Data Encryption, Data Backup and Recovery
Website and booking apps	DoS attack SQL Injection exposure of guest data Brute Force attack	insufficient bandwidth capacity Lack of data validation Insecure Authentication Inadequate password policy	Input Validation and Sanitization Data Encryption
Customer service management software	data loss unauthorized acces SQL injection	Weak Authentication Insufficient Data Encryption	Secure Communication Channels Backup and Recovery
Cloud Database	data interception data loss Account Hijacking	insecure authentication Lack of backups Weak and reuse passwords	Data Redundancy Data Backup and Disaster Recovery
Debit Card Machines	skimming devices social engineering Man-in-the-Middle Attack	Default or Weak Passwords Weak Encryption of Cardholder Data	Point-to-Point Encryption Tokenization Secure Card Readers
Data centers	Environmental Hazards Power Failure Distributed Denial-of-service attack	Weak Physical Security Insufficient Redundancy Improper allocation of resources	Physical Security Measures Network Traffic Monitoring
Wifi Extenders	Man-in-the-Middle Attack Eavesdropping	Default Configuration Settings Insecure Authentication and Weak	Network Segmentation Firmware Updates
Door Access Systems	physical temparing System Failures Credential Theft	Unauthorized Access Software Bugs or Glitches unsecured access control panels	tamper-resistant hardware Fault-Tolerant Architecture Emergency Override Tamper Alerts and Alarms
Smart Devices	Hacking devices Personal data Disclosure	Weak network protection Guest Wifi vulnerability Weak firewall protection	Guest Wifi encryption Control access to network
Stock Management systems	Inventory Theft or Loss Inventory Errors and Inaccuracies Supply Chain Disruptions	Weak Authentication and Access Controls Insecure Integration with External Systems	Data Encryption Supplier Contracts and Agreements Inventory Reconciliation
Power Reserve	Equipment Failure Fuel Supply Issues Insufficient Capacity Planning	Poor Maintenance Practice Fuel Contamination or Degradation Lack of Redundancy	Scheduled Maintenance Fuel Quality Testing Backup Generators Emergency Power Distribution
Routers	Botnet Infections DNS Spoofing Firmware Exploits	Open Ports and Services and Insecure Configuration Outdated Firmware or Software	Regular firmware updates Network Segmentation DNS Proxy and Filtering
Switches	remote code execution Device Compromise	Authentication Bypass and Buffer Overflow	Access Controls Secure Configuration Settings
Firewalls	brute force attcak evasion techniques zero-day exploits	Insufficient Logging and Monitoring Exposed Management Ports Packet Fragmentation Unpatched Software	IP Address Whitelisting/Blacklisting 2FA Patch Management IDPS
Food and beverage software	Service Disruptions Payment Card Fraud	outdated software versions unencrypted data transmissions improper data handling insufficient security controls	User Authentication Inventory Controls Transaction Monitoring
CCTV cameras	Physical Tampering Interference and Jamming	Insufficient encryption and authentication Firmware Vulnerabilities	Monitoring and Alerting Surveillance Signs Signal Filtering and Amplification

Name of Asset	Threat	Vulnerabilities	Existing Controls
Employee Service Centers	Physical Security Breach phishing Operational Disruptions	Weak Authentication Weak Access Controls Weak Spam filters	Strong password, Security Awareness Training Incident Response Plan
Computers	Data Loss or Theft Malware Phishing	Unpatched Software Weak Passwords Insecure Wi-Fi Networks	Data Backup and Recovery Antivirus Strong authentication
Social media accounts	account hacking phishing and scams data breach	Unauthorized Access by Former Employees Inadequate Security Settings	Multi-Factor Authentication (MFA) Regular Monitoring and Review

Overall risk calculation by Using Factor Analysis of Information Risk (FAIR)

We made the decision to compute the overall risk for all assets against various threats using the Factor Analysis of Information Risk (FAIR) method. By establishing exact probabilities for the frequency and magnitude of loss occurrences, the FAIR (Factor Analysis of Information Risk) model codifies a taxonomy of risk-influencing elements and their interrelationships.

Organisations can utilise the FAIR risk analysis methodology to prioritise risk treatments and quantify the financial impact of cyber risk. Additionally, it is a risk assessment methodology that can measure information risks' economic impact effectively. (Introduction to Information Security Risk Assessment using FAIR (Factor Analysis of Information Risk), 2019.)

Why we chose FAIR?

Most cybersecurity operations use a similar approach that is centred on complying with industry or governmental regulations, marking off controls or best practices, or both. Even though these methods are useful and essential, they don't address issues like:

- What are the major cyber dangers company can face, and how much exposure do they pose?
- What are the most important cyber risk management investments?
- Is cyber risk management getting enough (or too much) attention?

Accuracy is favoured and practised in the area of risk management, particularly with the FAIR model, since it provides for adequate flexibility and opportunity for scenario to give accurate and definite information. The effectiveness of FAIR (Factor Analysis of Information Risk) as a risk assessment technique is demonstrated by its capacity to perform cost-benefit analyses, prioritize important risk factors, quantitatively analyse risk, facilitate stakeholder communication, and provide scalability and flexibility. FAIR facilitates accurate and objective risk assessment by giving risk factors numerical

values. This helps organizations concentrate resources on critical risks and engage stakeholders in meaningful discussions about risk management strategies.

Considering existing controls for each asset and using FAIR analysis, below is the following estimate of the assets' total risk and strength:

Name of Asset	Threat	Existing Controls	TEF	Tcap	CS	Vulnerability	LEF	WC	PLM	Risk Value
Payroll systems	unauthorized access Fraudulent Conduct	Data Backups Audit Trails Approval Processes	H	M	M	M	H	High	High	Critical
Hard Drives	physical damage malware infections Data Corruption	Data Encryption, Data Backup and Recovery	H	H	M	H	H	High	High	Critical
Website and booking apps	DoS attack SQL Injection exposure of guest data Brute Force attack	Input Validation and Sanitization Data Encryption	M	H	H	M	M	High	High	High
Customer service management software	data loss unauthorized acces SQL injection	Secure Communication Channels Backup and Recovery	H	M	M	M	H	Severe	High	Critical
Cloud Database	data interception data loss Account Hijacking	Data Redundancy and Replication Data Backup and Disaster Recovery	H	H	M	H	H	Severe	High	Critical
Debit Card Machines	skimming devices social engineering Man-in-the-Middle Attack	Point-to-Point Encryption Tokenization Secure Card Readers	H	VH	H	H	H	Moderate	Significant	High
Data centers	Environmental Hazards Power Failure Distributed Denial-of- service attack	Physical Security Measures Network Traffic Monitoring	M	H	H	M	M	Severe	Severe	Critical
Wifi Extenders	Man-in-the-Middle Attack Eavesdropping	Network Segmentation Firmware Updates	M	L	H	VL	VL	Low	Moderate	Low
Door Access Systems	physical tampering System Failures Credential Theft	tamper-resistant hardware Fault-Tolerant Architecture Emergency Override Tamper Alerts and Alarms	M	H	VH	L	L	Significant	Moderate	Moderate

Name of Asset	Threat	Existing Controls	TEF	Tcap	CS	Vulnerability	LEF	WC	PLM	Risk Value
Smart Devices	Hacking devices Personal data Disclosure	Guest Wifi encryption Control access to network	H	M	H	L	M	High	High	High
Stock Management systems	Inventory Theft or Loss Inventory Errors and Inaccuracies Supply Chain Disruptions	Data Encryption Supplier Contracts and Agreements Inventory Reconciliation	M	M	VH	VL	VL	Low	Moderate	Low
Power Reserve	Equipment Failure Fuel Supply Issues Insufficient Capacity Planning	Scheduled Maintenance Fuel Quality Testing Backup Generators Emergency Power Distribution	L	M	VH	VL	VL	Low	Moderate	Low
Routers	Botnet Infections DNS Spoofing Firmware Exploits	Regular firmware updates and Network Segmentation DNS Proxy and Filtering Intrusion Detection and Prevention Systems (IDPS)	M	M	H	L	L	Moderate	Significant	Moderate
Switches	remote code execution Device Compromise	Access Controls Secure Configuration Settings Port Security and VLAN Segmentation	L	M	VH	VL	VL	Low	Moderate	Low
Firewalls	brute force attack evasion techniques zero-day exploits	IP Address Whitelisting/Blacklisting 2FA Patch Management IDPS	M	M	H	L	L	Moderate	Significant	Moderate
Food and beverage software	Service Disruptions Payment Card Fraud	User Authentication Inventory Controls Transaction Monitoring	L	L	H	VL	VL	Low	Moderate	Low
CCTV cameras	Physical Tampering Interference and Jamming	Monitoring and Alerting Surveillance Signs Signal Filtering and Amplification	M	M	H	L	L	Moderate	Moderate	Moderate
Employee Service Centers	Physical Security Breach phishing Operational Disruptions	Strong password, Security Awareness Training	M	M	H	L	L	Moderate	Significant	Moderate
Computers	Data Loss or Theft Malware Phishing	Data Backup and Recovery Antivirus Strong authentication	M	H	M	H	M	Significant	Significant	High

Risk Mitigation – ISO 27001

Proposed mitigating controls (based on ISO 27001 controls)

To secure organizations against a variety of threats and vulnerabilities, a strong information security management system (ISMS) must include mitigation controls based on ISO 27001. The international standard for information security management, ISO 27001, offers a thorough framework for creating, putting into practice, upholding, and continuously enhancing an ISMS. Within this framework, mitigation controls are proactive steps taken to lessen the probability and impact of security breaches, incidents, and other unfavourable occurrences.

These controls cover different aspects of information security risk management and are organized around several domains and categories. Organizations can improve their capacity to protect sensitive data, uphold regulatory compliance, and preserve their reputation by aligning with ISO 27001 controls and making sure that their mitigation strategies adhere to global best practices and standards.

Here are some details of proposed mitigation controls for Megahotel assets.

Asset Name	Risk Description	Risk Owner	Risk Value	Type of Treatment	Controls to be implemented & description	Controls to be implemented - ISO 27001 Clauses	Date	Responsible for applying the controls
Payroll systems	Data Loss Reputation damage	HR Director	Critical	Reduce	Protection of records Data leakage Prevention Access Control	A.5.33 A.8.12 A.5.15	Nov-24	HR Departement
Hard Drives	Data loss Operational disruptions	Chief Technology Officer	Critical	Reduce	Equipment maintenance Information deletion Logging	A.7.13 A.8.10 A.8.15	Jul-24	IT Departement
Customer service management software	Exposure of Guest Data	Chief Information Officer	Critical	Reduce	Access Rights Logging Classification of information	A.5.18 A.8.15 A.5.12	Jun-25	IT Departement
Cloud Database	Data Breach Identity Theft Loss of Competitive Advantage	Chief Information Officer	Critical	Reduce	Secure coding Data security awareness, education and training Segregation of duties	A.8.28 A.6.3 A.5.3	Oct-24	IT Departement
Data centers	Data Loss Security Breach	Chief Information Officer	Critical	Reduce	Segregation of duties Information security during disruption Access Control	A.5.3 A.5.29 A.5.15	Aug-24	IT Departement

Asset Name	Risk Description	Risk Owner	Risk Value	Type of Treatment	Controls to be implemented & description	Controls to be implemented - ISO 27001 Clauses	Date	Responsible for applying the controls
Website and booking apps	Exposure of Guest Data reputation damage	Chief Information Officer	High	Reduce	Remote Working Learning from information security incidents Secure development life cycle	A.6.7 A.5.27 A.8.25	Mar-25	IT Departement
Debit Card Machines	Fraudulent Transactions Reputation Damage	Chief Technology Officer	High	Reduce	Privacy and protection of personal identifiable information (PII) Contact with Authorities Secure system architecture and engineering principles	A.5.34 A.5.5 A.8.27	Jan-25	IT Departement
Smart Devices	Identity Theft Physical Safety Risks Reputation Damage	Chief Technology Officer	High	Reduce	Access Controls Authetication Information Secure system architecture and engineering principles	A.5.15 A.5.17 A.8.27	Apr-25	IT Departement
Computers	Loss of Sensitive Information Data Manipulation or Corruption Loss of Competitive Advantage Compromised Privacy	Chief Technology Officer	High	Reduce	Access Control Strong authentication	A.5.15 A..8.5	Mar-25	IT Departement
Routers	Network Disruption Malware Distribution	Director of IT Infrastructure	Moderate	Reduce	network security Privileged access rights Information security during disruption	A.8.20 A.8.2 A.5.29	Jun-24	IT departement
Firewalls	System Compromise Operational Disruption	Director of IT Infrastructure	Moderate	Reduce	Access control Information security during disruption	A.5.15 A.5.29	Jul-25	IT Departement
CCTV cameras	Loss of Surveillance Coverage Data Loss or Corruption Compromised Evidence	Chief Technology Officer	Moderate	Reduce	Access Controls Segregation of duties	A.5.15 A.5.3	Feb-25	Security Departement
Employee Service Centers	Data Breach Loss of trust	HR Director	Moderate	Reduce	Information Backup Information access restriction Incident Response Plan	A.8.13 A.8.3 A.5.26	Aug-24	HR Departement
Social media accounts	Loss of Control Spread of Malware	Chief Information Officer	Moderate	Reduce	Monitoring and Logging Information security event reporting	A.8.15 A.6.8	Mar-25	IT Departement

Statement of Applicability (SOA)

The SOA justifies each control measure's inclusion or exclusion based on the conclusions of the organization's risk assessment and the choices made regarding risk treatment. Additionally, it shows the stage of implementation for each control measure: fully implemented, partially implemented, or not implemented at all. In above tables we proposed some additional controls as per ISO27001 standards and below are some details of SOA of these controls.

➤ **Monitoring and Logging: (A.8.16, A.8.15)**

All activities must be recorded on all kind of devices and networks and logs should be maintained time to time and their monitoring must be done after a proper period. Meanwhile if any activity beyond company policy is in progress a red flag must be generated to authorities.

➤ **IS awareness, education, and training and Segregation of duties: (A.6.3, A.5.3)**

Employee training sessions will prevent cyberattacks and establish appropriate labor division policies, ensuring each owner has their responsibilities and avoids interference with other departments or fields.

➤ **Strong Authentication: (A.8.5)**

Control measures such as multi-factor authentication and strong password policies aim to reduce account hacking and ensure secure access. These measures include account lockout, password complexity, frequency of changes, secure storage, and user awareness training.

➤ **Access Control: (A.5.15)**

The control objective focuses on establishing robust access control systems to ensure the confidentiality, integrity, and availability of information assets. This involves implementing policies, biometric authentication, least privilege principle authorization, monitoring and logging access activities, and regularly reviewing access rights to ensure compliance with security guidelines and legal requirements.

➤ **Information security event reporting: (A.6.8)**

The control objective focuses on systematically identifying, reporting, and managing security incidents through event reporting. Control measures include defining incident classification parameters, assigning responsible parties, and establishing reporting protocols, ensuring effective documentation and escalation.

➤ **Classification of information: (A.5.12)**

The control aim is to implement a systematic approach to classification, focusing on systems, practices, and data subject to classification. This involves developing classification criteria, assigning responsibility, providing training, establishing technical safeguards, and regularly reviewing and modifying classification decision.

➤ **Secure coding: (A.8.28)**

Secure software development requires strong coding standards, including creating guidelines, offering developer training, conducting code reviews, incorporating security testing, and using automated tools to enforce secure coding practices in the software development lifecycle.

➤ **Privacy and protection of personal identifiable information (PII): (A.5.34)**

Objective of this control to establish a strong safeguard to prevent unauthorized access, disclosure, alteration, or destruction of personal data. A strong safeguard is in place for data processing, ensuring the protection of personal data from unauthorized access, disclosure, alteration, or destruction, through regular risk assessments, consent, encryption, and control.

➤ **Information Backup: (A.8.13)**

By implementing regular backup procedures, this control aim is to create strong mechanisms that guarantee the availability and integrity of vital information. Regular backup procedures ensure the availability and integrity of vital information by defining requirements, creating schedules, implementing backup technologies, regularly testing and auditing backups, and ensuring off-site data storage.

➤ **Remote Working Policy: (A.6.7)**

Control systems are crucial for remote work, ensuring secure access and protection of sensitive data. The control objective is to implement secure technologies like VPNs and MFA, create policies, and provide regular security awareness training to remote employees.

➤ **Secure system architecture and engineering principles: (A.8.27)**

This Control technology focuses on creating safe systems through secure design principles, implementing strong procedures, and managing them to guard against cybersecurity threats. This includes applying safe coding techniques, conducting routine security architecture reviews, and implementing encryption and access controls.

Risk Reduction (SOA)

The suggested controls outlined in the Statements of Applicability (SoA) are intended to reduce or control particular information security risks. The quality of the controls' implementation, adherence to rules and procedures, and the particular circumstances of the company all affect how effective these controls are at reducing risk. Below is an overview of how these controls can contribute to risk reduction:

➤ **Monitoring and Logging**

Controls and monitor all ongoing activities in network and web servers. Including all applications and devices as well and it will reduce risk of unauthorized activity.

➤ **IS awareness, education, and training and Segregation of duties:**

It will make all employee up to date about company network security policies and also with help of duties segregation everyone will focus on their own work and domain.

➤ **Strong authentication policy:**

With help of strong password policy and MFA there will less risk of password theft or unauthorized access to different domains and logins.

➤ **Access Control:**

Access control will ensure integrity, confidentiality, and privacy of information data. It will help to reduce risk of information data losses and also it will reduce impact of any kind of cyber-attack related to data.

➤ **Information security event reporting:**

Information security event reporting will increase efficiency of reporting time and then recovery policy could be more effective. In this case response time of any incident will be more effective.

➤ **Classification of information:**

Classification of information will help to categorize information structure and it will define who can have access to which information. This will reduce the risk of information loss.

➤ **Secure coding:**

Secure coding will reduce chances of data breaching and unauthorized access to main code. It will help against all kind of malicious network attack and secure programming data base.

➤ **Privacy and protection of personal information:**

Privacy protection policy of PI will help to secure all customers personal data and it will reduce all kind of data theft, data manipulation and data loss risks.

➤ **Information Backup:**

Along with the antivirus protection control which avoids the malwares from the corrupting the data, another control of regular data will help to keep the data secure and prevent any kind of data losses in case of any emergency or incident.

➤ **Remote Working policy:**

With implementation of this control risk caused by remote working setup will be reduce drastically. It will ensure company data and important information to be leaked and unauthorized access.

➤ **Secure system architecture and engineering principles:**

With this control network system architecture will be safer of phishing emails and against spoofing. It will reduce risk of cyber-attacks against network and firewalls.

Risk treatment plans – Risk acceptance, risk treatment, risk transfer and risk avoidance

Within the ISO 27001 framework, the Risk Treatment Plan (RTP) is a scope that acts as a guide for organizations on how to properly address and mitigate risks that have been identified. Serving as a tactical guide, the RTP specifies the precise steps and safeguards that must be put in place to lower the probability and severity of risks to a manageable level. It gives risk management initiatives a clear direction and is in line with the organization's risk tolerance and business goals. Below are four different approaches we can utilise as RTP.

➤ **Risk acceptance:**

This technique usually involves accepting a certain amount of risk and choosing not to take additional steps to reduce it. It is usually selected when the organization is willing to accept the risk, the potential impact of the risk is low, or the cost of mitigation is too high.

➤ **Risk Treatment:**

Risk treatment is the process of putting policies in place to reduce the possibility or effect of hazards that have been identified to a manageable level. This can involve putting in place safeguards, procedures, or controls to reduce risks, assigning risks to other parties via contracts.

➤ **Risk transfer:**

Risk transfer is the process of shifting the financial consequences of a risk to another party, typically through outsourcing or insurance. By shifting risk, organisations can protect themselves from financial losses caused by negative events.

Risk avoidance:

The goal of risk avoidance is to reduce or stop any exposures, procedures, or activities that put the company at intolerable risk. Despite its seeming extremeness, this strategy may be appropriate for risks that have serious repercussions or that cannot be adequately mitigated in any other way.

In our risk mitigation plan we proposed Risk treatment or risk reduction approach as below.

Asset Name	Risk Description	Type of Treatment	Controls to be implemented & description	Controls to be implemented - ISO 27001 Clauses
Payroll systems	Data Loss Reputation damage	Reduce	Protection of records Data leakage Prevention Access Control	A.5.33 A.8.12 A.5.15
Hard Drives	Data loss Operational disruptions	Reduce	Equipment maintenance Information deletion Logging	A.7.13 A.8.10 A.8.15
Customer service management software	Exposure of Guest Data	Reduce	Access Rights Logging Classification of information	A.5.18 A.8.15 A.5.12
Cloud Database	Data Breach Identity Theft Loss of Competitive Advantage	Reduce	Secure coding Data security awareness, education and training Segregation of duties	A.8.28 A.6.3 A.5.3
Data centers	Data Loss Security Breach	Reduce	Segregation of duties Information security during disruption Access Control	A.5.3 A.5.29 A.5.15
Website and booking apps	Exposure of Guest Data reputation damage	Reduce	Remote Working Learning from information security incidents Secure development life cycle	A.6.7 A.5.27 A.8.25
Debit Card Machines	Fraudulent Transactions Reputation Damage	Reduce	Privacy and protection of personal identifiable information (PII) Contact with Authorities Secure system architecture and engineering principles	A.5.34 A.5.5 A.8.27
Smart Devices	Identity Theft Physical Safety Risks Reputation Damage	Reduce	Access Controls Authetication Information Secure system architecture and engineering principles	A.5.15 A.5.17 A.8.27

Asset Name	Risk Description	Type of Treatment	Controls to be implemented & description	Controls to be implemented - ISO 27001 Clauses
Computers	Loss of Sensitive Information Data Manipulation or Corruption Loss of Competitive Advantage Compromised Privacy	Reduce	Access Control Strong authentication	A.5.15 A..8.5
Routers	Network Disruption Malware Distribution	Reduce	network security Privileged access rights Information security during disruption	A.8.20 A.8.2 A.5.29
Firewalls	System Compromise Operational Disruption	Reduce	Access control Information security during disruption	A.5.15 A.5.29
CCTV cameras	Loss of Surveillance Coverage Data Loss or Corruption Compromised Evidence	Reduce	Access Controls Segregation of duties	A.5.15 A.5.3
Employee Service Centers	Data Breach Loss of trust	Reduce	Information Backup Information access restriction Incident Response Plan	A.8.13 A.8.3 A.5.26
Social media accounts	Loss of Control Spread of Malware	Reduce	Monitoring and Logging Information security event reporting	A.8.15 A.6.8

Risk Communication Plan

The risk communication plan outlines how the required steps to reduce the risk the risk will be conducted out and how the risk message will be appropriately communicated to the appropriate authorities. We developed a comprehensive risk communication plan for the company because of the audit and risk treatment plan.

Risk/Threat	Impact	Timing	Sender	Target Audience	Key Messages	Desired Outcome	Method of Communication
DoS attack	Service Disruption or Unavailability, Loss of Revenue and Productivity, Operational Disruption and Recovery Costs	2nd Quarter of 2024	CIO	Info Sec Team IT Team	Implement Rate Limiting and Traffic Filtering Deploy DoS Protection Solutions Distribute Traffic and Scale Resources	Improve network performance, availability, and security posture, enhance resilience	Meeting and Training Workshops
SQL Injection	Data leakage and manipulation, unauthorized access	2nd Quarter of 2024	CIO	Info Sec Team IT Team	Implement Server side Validation, Database Security Controls, and Security Awareness Training	Decrease the possibility and effect of security incidents, secure private data, and promote a resilient and security-aware environment	Meeting
Man-in-the-Middle Attack	Data interception and tampering, trust erosion	1st Quarter of 2025	CTO	Info Sec Team IT Team Networking Team	Implement Digital Certificates and Public Key Infrastructure (PKI), Network Segmentation and Isolation and Endpoint Security	Reduce the effects of security incidents and strengthens endpoint security to fend off malware threats and unauthorized access	Meeting and Training Workshops
physical tempering	Compromise of Confidentiality, Integrity Violation, Disruption of availability, Bypassing security controls	3rd Quarter of 2024	CTO	IT team Security Team	Implement Access Control Measures, Physical Barriers and Deterrents and train and aware the employees	create a secure and resilient environment	Meeting
Eavesdropping	Data Breach, Privacy Violation, Loss of confidentiality, National Security Risk	1st Quarter of 2025	CIO	Info Sec Team IT Team	Implement Virtual Private Networks (VPNs), Regular Audits and Monitoring	enhance data protection, reduce risk of unauthorized access, and ensure compliance with regulations, incident detection, response capabilities, visibility, resilience, and continuous improvement	Meeting and Training Workshops
Account Hijacking	Financial Loss, Data breach, Identity Theft, Credential Stuffing and Account Abuse	2nd Quarter of 2024	Head of InfoSec	CTO CISO CIO IT Head	Implement strong authentication, account monitoring and account recovery procedures	enable proactive detection and response to security incidents, and protect user accounts and sensitive information	Meeting
System Failures	Productivity Loss, Data loss and Corruption, Recovery Cost, Reputational Damage and Stakeholder Confidence	3rd Quarter of 2024	CIO	Info Sec Team IT Team	Implement Regular Maintenance and Updates, Testing and Simulation and Proactive Monitoring and Predictive Analytics	enhance reliability, resilience, efficiency customer satisfaction, and competitive advantage	Meeting and Training Workshops
Credential Theft	Unauthorized access, data breach, identity theft and fraud, compromised account	3rd Quarter of 2024	CIO	Info Sec Team IT Team	Implement Strong Authentication Practices, Email Security Measures, and Continuous Monitoring and Detection	strengthen cybersecurity defenses, protect information and crucial assets, and assure resilience against emerging risks and cyberattacks	Meeting
DNS Spoofing	Phishing and Malware distribution, Financial Loss, Reputation Damage	1st Quarter of 2025	Head of InfoSec	CTO CISO CIO IT Head	Implement DNS Cache Management, DNS Monitoring, Logging, Firewalling and Filtering	improve DNS security posture, reduce risks associated with DNS, and maintain the reliability, availability, and integrity of DNS services for users and applications	Meeting and Training Workshops
Brute Force Attack	Data theft, Password breach	2nd Quarter of 2024	CIO	Info Sec Team IT Team	Implement Multifactor Authentication, Rate Limiting and CAPTCHA	reduce risks, restrict attackers, and deliver a more reliable and safe authentication system	Meeting and Training Workshops
Malware	Data loss or theft, system disruption, reputation damage, compromised system integrity	3rd Quarter of 2024	Head of InfoSec	CTO CISO CIO IT Head	Deploy antivirus and antimalware software, Web Filtering and Content Filtering	improve the organization's cybersecurity measures, reduce data loss and security risks, and foster a secure and productive computing environment	Meeting
zero-day exploits	System Compromise, Cyber Espionage and Warfare, Social and Economic Disruption	1st Quarter of 2025	CTO	Info Sec Team IT Team Networking Team	Implement Vulnerability and Patch Management, Intrusion Detection and Prevention	strengthen the security posture of the organization, mitigate the risk and impact of security incidents, and make sure that new threats and vulnerabilities are promptly detected and addressed	Meetings and Training Workshops
evasion techniques	Increased Risk of Successful Attacks, Delayed Incident Response, Compromise of Sensitive Data, Disruption of Business Operations	3rd Quarter of 2024	Head of InfoSec	CTO CISO CIO IT Administrator	Implement Deep Packet Inspection, Conduct traffic Analysis, and employ Anti-Evasion Techniques	improve network security, forensic analysis, incident response, threat prevention, and detection to protect against new and evolving cyber threats and ensure network infrastructure integrity	Meeting
Botnet Infections	Network Congestion and Bandwidth Drain, Malicious Activities and Attacks, Compromised System Performance	2nd Quarter of 2024	CTO	IT team Networking Team	Deploy Endpoint Security, Botnet Detection and Monitoring	enhance safety measures, protect crucial information and assets from cyber threats, and ensure regular monitoring and detection	Meeting and Training Workshops
Equipment Failure	Financial Costs, Data Loss and Security Risks, Service Disruptions, Operational Delays and Recovery Efforts	3rd Quarter of 2024	CTO	IT team	Implement regular maintenance schedule, Predictive Maintenance, Training and Skill Development	increase performance, save maintenance costs, reduce delay, and boost equipment resilience	Meeting
Phishing	Loss of Productivity, Data Breach, Credential Theft, Social Engineering Exploitation	2nd Quarter of 2024	Head of InfoSec	CTO CISO CIO IT Administrator	Implement protective measures to protect, detect, and configure Development and awareness	encourage secure configuration practices, and improve threat detection,	Meeting

Business Continuity Plan

Business continuity planning, or BCP, is the process of creating a plan to shield and recover a company from potential risks. In the event of a crisis, the plan ensures that personnel and property are protected, and that business can quickly resume. BCP is an essential part of the risk management strategy because it involves listing all potential risks to the organization's operations. (Investopedia, 2022)

A business continuity plan involves business impact analysis, recovery strategies, response, and recovery processes, testing and training, documentation and maintenance, coordination and communication, review, and improvement. BCPs help organizations reduce the impact of disruptions, protect their reputation and revenue, and ensure long-term resilience and viability by identifying potential threats, evaluating their impact on crucial business functions, and developing proactive measures to mitigate risks and maintain essential operations. To guarantee that the BCP is effective and that it is in line with changing business needs and risks, regular testing, training, and reviews are crucial.

Business Impact Analysis

A business impact analysis is carried out to emphasize the importance of business processes and activities and their corresponding needs to guarantee the continuation of operations both during and after a disruption. The research evaluates the impact of disruptions on the process, goals for recovery point and recovery time, and disaster recovery plan. The development of business continuity plans and protocols in the case of a cyberattack is then done using these criteria.

Recovery Time Objectives (RTO)

Recovery time targets clarify the maximum amount of time that can be supposed to access to after an attack or disaster before a service or process is restored to prevent business continuity from being disrupted.

Essentially, the RTO measures how long a company can afford to be without its essential operations or services before the consequences become intolerable. A careful balance must be struck when establishing recovery time objectives (RTOs) between the potential losses during downtime and the cost of putting recovery measures into place. We've determined the following recovery time targets for each audited asset by evaluating its workload and condition.

Critical Asset	BIA Owner	Assessment Date	Review Date	Maximum Tolerable Period of Disruption	Impact	Recover Time Objective
Payroll systems	HR	May 25, 2024	June 15, 2024	2-3 days	High	7-8 hrs
Hard Drives	IT Adminstator	May 25, 2024	June 15, 2024	1 day	Critical	5-6 hrs
Customer service management software	IT Adminstator	June 25, 2024	July 15, 2024	2 days	Critical	2-3 hrs
Cloud Database	IT Adminstator	May 25, 2024	June 15, 2024	1-2 days	High	4-5 hrs
Data centers	CISO	June 25, 2024	July 15, 2024	1 day	Critical	3-4 hrs
Website and booking apps	CISO	June 25, 2024	July 15, 2024	1 day	High	4-5 hrs
Debit Card Machines	CISO	May 25, 2024	June 15, 2024	1 day	High	4-5 hrs
Smart Devices	IT Adminstator	June 25, 2024	July 15, 2024	1-2 days	High	4-5 hrs
Computers	IT Adminstator	June 25, 2024	July 15, 2024	1-2 days	High	4-5 hrs

Recovery Point Objectives (RPO)

The maximum amount of data loss that can be accepted in the wake of a denial-of-service or cyberattack, expressed in terms of time, is known as the recovery point objective. In essence, it indicates the time just prior to the event at which information may be correctly retrieved. If an asset is targeted, the recovery point objective shows how much data will be lost and how much time it will take to recover that data.

After auditing most of the firm's assets, the measured RPO for each of the assets mentioned below is as follows:

Critical Asset	BIA Owner	Assessment Date	Review Date	Maximum Tolerable Period of Disruption	Impact	Recovery Point Objective
Payroll systems	HR	May 25, 2024	June 15, 2024	2-3 days	High	1 day
Hard Drives	IT Adminstator	May 25, 2024	June 15, 2024	1 day	Critical	2 days
Customer service management software	IT Adminstator	June 25, 2024	July 15, 2024	2 days	Critical	1-2 days
Cloud Database	IT Adminstator	May 25, 2024	June 15, 2024	1-2 days	High	3 days
Data centers	CISO	June 25, 2024	July 15, 2024	1 day	Critical	2 days
Website and booking apps	CISO	June 25, 2024	July 15, 2024	1 day	High	1-2 days
Debit Card Machines	CISO	May 25, 2024	June 15, 2024	1 day	High	1-2 days
Smart Devices	IT Adminstator	June 25, 2024	July 15, 2024	1-2 days	High	1-2 days
Computers	IT Adminstator	June 25, 2024	July 15, 2024	1-2 days	High	1-2 days

Disaster Recovery Plan

The purpose of the disaster recovery plan is to guarantee the quick restoration of vital systems or procedures after an interruption. It is intended to reduce downtime, safeguard vital systems, and guarantee the organization's ability to bounce back from traumatic events. Maintaining the efficacy of the plan requires regular testing, training, and updates. As per our assessment below is DR Plan for our critical assets.

Critical Assets	Proposed DR Solution	Responsibility
Payroll systems	Regular backup Failover and Redundancy out sourcing	HR Department
Hard Drives	Offsite Backup Storage Disk Imaging Data Recovery Procedures	IT Administrator
Customer service management software	Data Backup and Replication Geographic Redundance Regular Testing and Maintenance	IT Administrator
Cloud Database	Data Backup Load Balancing Automated Failover	IT Administrator
Data centers	Cloud data backup Parallel network availability Testing and Training for DR	IT Administrator

➤ **PayRoll Systems:**

For payroll system in case of any disaster organization must have all data regular backups and have proper system as backup plan. Also, there should be outsourcing option in case of any emergency. Establish failover mechanisms and redundancy measures to minimize downtime and ensure continuous payroll processing.

➤ **Hard drives:**

For all kind of hard devices should have backup storage and must be offline storage. Also, there should be disk imaging available so in case of any disaster organization must have its data saved up.

➤ **Customer Service Management Software:**

Customer service management is very critical in hotel business and in case of any network safety incident there must be data backups which is essential part. Meanwhile on other hand employees must have regular training and testing for all procedure which must be done during or after cyber-attack.

➤ **Cloud Database:**

Cloud data base is very important part of today's advanced network structure. And in disaster recovery plan it should have data load balancing with data backup as well. On other hand automated failover mechanism must be strong and effective so it can reduce downtime as much as possible.

➤ **Data Centres:**

Data centres are hub of all important data and networking devices. It must have very strong disaster recovery plan including cloud data backups on different servers. Also there should be parallel network structure availability must be present there so in case of any cyber incident all services can be shifted to that network until data centres services are restored. And all employees must have full aware and should be trained for this practice.

Conclusion:

Considering all this, the focus of our discussion was on enhancing data security and business flexibility through the implementation of controls, risk management protocols, and business planning. We thoroughly examined the identification of resources and suggested controls, such as access control, logging and monitoring, privacy and protection of personal information, cryptography, and a plan for employee education and training with clear recovery objectives for fundamental frameworks. The treatment plans for gambling focused on risk recognition, mitigation, transition, and avoidance, tailored to the association's unique needs. This comprehensive approach aims to protect the organization from potential threats by ensuring the integrity, accessibility, and classification of fundamental data and processes. Maintaining a strong and adaptable security posture in the constantly evolving landscape of data security and business coherence requires ongoing review, testing, and modification of these plans. To mitigate the risk, we have proposed measures that will reduce it to the barest minimum. If suggested actions be carried out in accordance with the audited plan, the Megahotel can have successful merger with full safety from all kinds of cyber-attacks.

References

- Irwin, L. (2020). *Risk terminology: Understanding assets, threats and vulnerabilities*. [online] Vigilant Software - Compliance Software Blog. Available at: <https://www.vigilantsoftware.co.uk/blog/risk-terminology-understanding-assets-threats-and-vulnerabilities#:~:text=An%20asset%20is%20any%20data,would%20applications%20on%20those%20devices>. [Accessed 11 April2022].
- Ncsc.gov.uk. (2022). *Understanding vulnerabilities*. [online] Available at: <https://www.ncsc.gov.uk/information/understanding-vulnerabilities> [Accessed 29th April 2022].
- Britton, T. (2019). *How to Define Severity and Likelihood Criteria on Your Risk Matrix*. [online] Asms-pro.com. Available at: <http://aviationsafetyblog.asms-pro.com/blog/how-to-define-severity-and-likelihood-criteria-on-your-risk-matrix#:~:text=Severity%20on%20the%20risk%20matrix,likely%20problem%20that%20will%20occur>. [Accessed 11 April 2022].
- Introduction to Information Security Risk Assessment using FAIR (Factor Analysis of Information Risk). (n.d.). [online] Available at: <https://www.aujas.com/hubfs/Introduction-to-Information-Security-Risk-Assessment-using-FAIR-1.pdf>.

- Risklens.com. (2019). *Introducing FAIR-U: A Free Training App for FAIR*. [online] Available at: <https://www.risklens.com/resource-center/blog/introducing-fair-u-the-free-way-to-try-fair#:~:text=January%2024%2C%202019%20Bryan%20Smith,single%2Dscenario%20FAIR%20risk%20analyses>. [Accessed 05 April 2022].
- Oclc.org. (2022). *Home :: BSOL British Standards Online*. [online] Available at: <https://bsol-bsigroup-com.bcu.idm.oclc.org/> [Accessed 05 May 2022].
- ISO 27001 (2018). *ISO 27001*. [online] Itgovernance.co.uk. Available at: <https://www.itgovernance.co.uk/iso27001#:~:text=ISO%2027001's%20best%2Dpractice%20approach,with%20information%20security%20best%20practices>. [Accessed 1 May 2022].
- Investopedia. (2022). *Business Continuity Planning (BCP)*. [online] Available at: <https://www.investopedia.com/terms/b/business-continuity-planning.asp> [Accessed 08 May 2022].